

Seguridad Arquitectónica

Mecanismos: WAF · MFA · sanitización · encriptación · VPN · reverse proxy · defense in depth

Ingeniería de Software II · ITBA · 2026-1C · Repaso conceptual

RESUMEN

La **Security** arquitectónica no es defensa absoluta: es *threshold defense* — subir el costo del ataque hasta que el adversario racional elija otro target. Se materializa con un catálogo de mecanismos (WAF, MFA, sanitización, encriptación, reverse proxy, VPN) compuestos en capas (*defense in depth*), y con decisiones de hosting/data residency que determinan qué arquitectura es siquiera legal. La inversión es proporcional a la **naturaleza de los datos**.

§1 Filosofía: Security como threshold defense

FUENTE

"Lo más importante que tiene una empresa es la información de sus usuarios." · "El objetivo es ser lo suficientemente difícil de entrar para que sea más atractivo hackear a otro." (source: mecanismos-de-seguridad.md, Clase 7)

- **Security no es absoluta.** Defenderse perfecto es imposible y carísimo; defenderse "lo suficiente" es viable y mueve el ataque hacia objetivos más blandos.
- **Cuánto invertir lo define el dato.** Healthcare / financiero: altísimo. Catálogo público de productos: bajo. La regulación y la consecuencia de la exposición fijan el piso (source: mecanismos-de-seguridad.md).

Atributo de calidad que se está optimizando: **SECURITY** — siempre en tensión con otros (ver trade-offs, §4).

§2 Catálogo de mecanismos

Cada mecanismo responde a un **escenario de amenaza** concreto y se ubica en un punto del flujo (source: mecanismos-de-seguridad.md).

WAF — Web Application Firewall

DEFINICIÓN

WAF: firewall de **capa 7** que inspecciona tráfico HTTP/S **antes** del backend. Filtra patrones conocidos (SQLi, XSS, path traversal), aplica rate limiting, geo-blocking y reglas OWASP CRS.

- **Protege contra:** DDoS, scraping abusivo, payloads maliciosos en requests.
- **Dónde va:** lo más afuera posible — entre internet y el Load Balancer/edge, antes de cualquier servicio aplicativo.
- **Productos:** AWS WAF, Cloudflare, Akamai, ModSecurity (open source).

MFA — Multi-Factor Authentication

DEFINICIÓN

MFA: la autenticación exige **al menos dos factores de naturaleza distinta**: algo que **sabés** (password), algo que **tenés** (TOTP, SMS, hardware key) y/o algo que **sos** (biometría). Robar el password ya no alcanza.

- **Protege contra:** robo de credenciales — el atacante necesita además el 2º factor, que está físicamente con el usuario.
- **Dónde va:** en el backend, sobre operaciones sensibles (login, cambio de credenciales, transferencia de fondos). No en cada interacción.
- **Productos:** Authy, Google Authenticator, Auth0/Okta MFA, AWS Cognito, WebAuthn/FIDO2 (passkeys).

TRADE-OFF

Security ↔ Usability: MFA agrega fricción real. Se resuelve aplicándolo selectivamente por operación/rol, no a todos siempre (source: mecanismos-de-seguridad.md).

Sanitización / validación de inputs

DEFINICIÓN

Sanitización: **validar y normalizar** todo input externo antes de usarlo. Dos formas complementarias: **allow-list** (definir lo válido, rechazar el resto) y **escaping/parametrización** (prepared statements para SQL; escape de < > & " ' en HTML; evitar concatenar en shell).

- **Protege contra:** SQL Injection, XSS, command injection, LDAP injection, XXE.
- **Dónde va:** en cada capa que recibe input del exterior — no solo el frontend.

REGLA DE ORO

Never trust user input. Si la BD ya guarda datos sanitizados, una vulnerabilidad nueva en el frontend no compromete los datos: eso es defense in depth (source: mecanismos-de-seguridad.md).

Encriptación at-rest e in-transit

DEFINICIÓN

At-rest: los datos se almacenan **cifrados en disco**; la clave vive en sistema separado (KMS / HSM / vault) y el motor descifra in-memory al leer. Modalidades: **TDE** (transparente a la app), **column-level** (solo PII / credit card), y encriptación de **backups** con clave y retención propias.

- **Protege contra:** acceso al storage físico (disco, backup, snapshot) — un leak físico no entrega datos legibles.
- **Dónde va:** en la capa de persistencia (BD, backups, snapshots).

CUÁNDO NO • CUIDADO

At-rest sin in-transit deja un flanco e in-transit sin at-rest expone los datos ante un leak físico. Van juntas: **in-transit = TLS 1.2+** sobre el cable (source: mecanismos-de-seguridad.md).

Reverse proxy / Load Balancer como proxy

DEFINICIÓN

Reverse proxy: proxy entre internet y el backend que **centraliza preocupaciones transversales** en lugar de replicarlas en cada servicio: terminación TLS (certificados en un solo lugar), distribución de carga, rate limiting por IP/usuario, inyección/limpieza de headers (X-Forwarded-For), IP whitelisting/blacklisting.

- **Protege contra:** dispersión de la lógica de seguridad y exposición directa de servicios; concentra el punto de control.
- **Dónde va:** detrás del WAF, delante del backend.
- **Productos:** Nginx, HAProxy, Traefik, Envoy, AWS ALB. En el [[Caso Compraventa de Acciones]] el LB es un **Nginx** que cumple este rol (source: mecanismos-de-seguridad.md).

VPN — Virtual Private Network

DEFINICIÓN

VPN: túnel cifrado punto a punto entre redes confiables. El sistema externo "entra" a la red privada del backend como si fuera local; el resto de internet no ve esa conexión.

- **Protege contra:** exposición a internet de sistemas que deben acceder al backend (proveedores de cotización, consola de Ops) sin ser públicos.
- **Dónde va:** conecta **sistemas externos confiables** directo a la zona privada, saltando la entrada pública (WAF + LB).

EJEMPLO

En el [[Caso Compraventa de Acciones]] la consola de Ops se mueve a infraestructura separada (Back + BD propios) accedida vía VPN. Reduce el *blast radius*: una vulnerabilidad en el SPA público no afecta al sistema de Ops (source: mecanismos-de-seguridad.md).

Segmentación en zonas de confianza

Zona pública (internet)

entra por WAF + LB.

Zona privada (intranet)

backend, BDs, servicios internos.

Sistemas externos confiables

conectan a la zona privada vía VPN.

§3 Composición: Defense in Depth

DEFINICIÓN

Defense in depth: ningún mecanismo basta por sí solo — se apilan **capas independientes**, cada una atrapa una clase de ataque. Si una falla, las otras siguen. El atacante debe romper varias defensas, lo que multiplica costo y tiempo: así se materializa la *threshold defense* (source: mecanismos-de-seguridad.md).

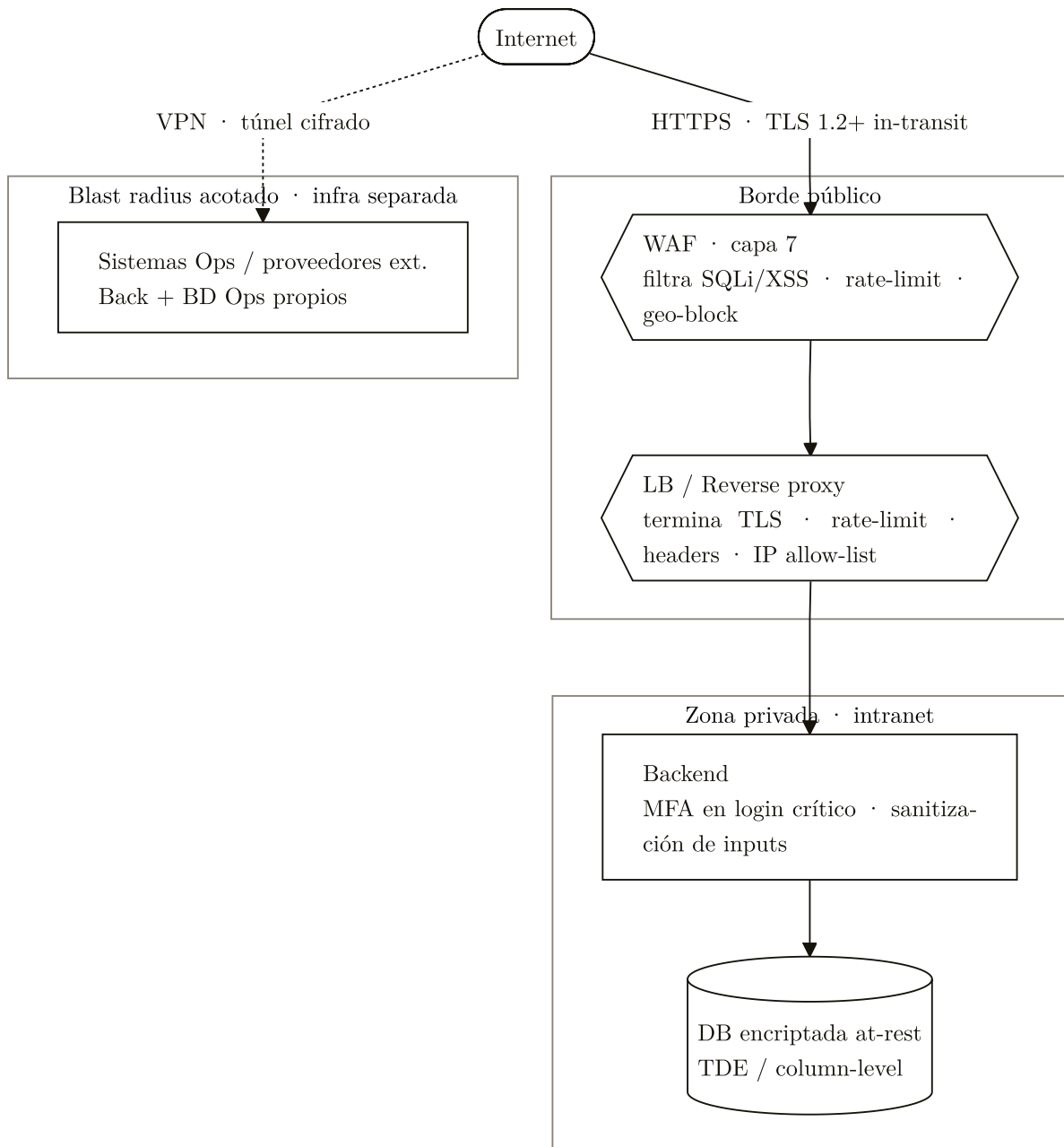


FIGURA 1. *Defense in depth:* todo tráfico público atraviesa WAF y LB antes del backend; la BD nunca habla con internet y los sistemas de Ops entran por VPN, acotando el blast radius.

Cada flecha de entrada pública pasa por WAF → LB. La VPN evita exponer sistemas internos al borde público. La BD nunca habla directo con internet.

§4 Decisiones y trade-offs canónicos

TABLA 1. Heurísticas de decisión (Clase 7)

Pregunta	Heurística
¿Cuánto invertir?	Proporcional a la naturaleza de los datos . Healthcare/financial: altísimo; catálogo público: bajo.
¿Dónde el WAF?	Lo más afuera posible — antes que cualquier servicio aplicativo.
¿MFA en todo?	No. Solo en operaciones sensibles (login, cambio de credenciales, transacciones).
¿At-rest siempre?	Sí para PII / datos financieros / regulados. Sobrecarga marginal con motores modernos.
¿VPN o endpoint público con auth?	VPN cuando controlás ambos extremos (sistemas internos, proveedores fijos). Exposición pública con auth para clientes finales.

TRADE-OFF

Security cuesta en cuatro ejes: ↔ **Usability** (MFA, timeouts, captchas friccionan), ↔ **Performance** (WAF agrega 1–10 ms; allow-list pesa CPU), ↔ **Maintainability** (más capas = más componentes que parchear/monitorear/rotar claves), ↔ **Time-to-market** (source: mecanismos-de-seguridad.md).

CUÁNDO NO • CUIDADO

Contraejemplo: en [[Caso Healthcare.gov]] la presión política bajó la barra de seguridad operacional (Security ↔ Time-to-market mal resuelto): sanitización, auth y auditoría tardías contribuyeron al colapso (source: mecanismos-de-seguridad.md).

§5 Hosting y data residency

DEFINICIÓN

Por qué es arquitectónico: dónde **vive físicamente** el sistema (cloud / on-premise / colocation / híbrido) condiciona Availability, Performance, Security, Maintainability, Auditability y costos. No es decisión "post-arquitectura": determina qué arquitectura es viable y cuál es legal (source: criterios-hosting-data-residency.md).

Criterio 1 — Marco regulatorio (data residency)

Algunas jurisdicciones obligan a que los datos de sus residentes **residan físicamente** en su territorio o jurisdicción legal. Ignorarlo no es una optimización: es ilegal.

TABLA 2. Restricciones canónicas (Clase 8)

Jurisdicción	Restricción
Corea del Sur	Datos de residentes coreanos en data centers ubicados en Corea del Sur.
México (1ª gestión Trump)	Datos financieros mexicanos en al menos un data center fuera de regulación de EE.UU.
UE — GDPR	Transferencia a terceros países requiere mecanismo legal (Schrems II invalidó Privacy Shield; ahora SCCs + TIA).
AR — Ley 25.326	Transferencia al exterior solo si el receptor tiene legislación adecuada (lista cerrada del registro).
BR — LGPD	Modelo similar a GDPR; transferencia internacional restringida.
Financiero (CNV/BCRA, SEC)	Reportes regulatorios accesibles al regulador local.
Salud (HIPAA, Ley 26.529 AR)	Datos clínicos con restricciones de almacenamiento y acceso.

CUÁNDO SÍ • VENTAJAS

Implicancia arquitectónica: multi-jurisdicción → **multi-region con sharding por residencia** (no por load). Regulador que inspecciona → **logs y datos accesibles localmente**. Transferencia internacional legítima → **encriptación + DPA + auditoría** del proveedor (source: criterios-hosting-data-residency.md).

Criterio 2 — Costos (trade-off obligatorio: costos vs tiempo)

TABLA 3. Modalidades de hosting (Clase 8)

Modalidad	Capex	Opex	Tiempo a prod.	Riesgos
Cloud público	Bajo	Alto (crece con uso)	Días–semanas	Lock-in, costo creciente con escala
On-premise propio	Muy alto (hw, racks, refrigeración)	Bajo (energía + staff)	Meses–1 año	Imprevistos de hw, capacidad rígida
Colocation (DC alquilado)	Medio (hw propio)	Medio (rack + energía + staff)	Semanas–meses	Lock-in del colo, SLAs del proveedor
Híbrido	Variable	Variable	Variable	Complejidad operativa duplicada

EJEMPLO

Patrón mediano: el "on-premise" suele ser en realidad un **colocation** — el equipo es propio, pero espacio, energía y conectividad se alquilan a un data center (Equinix, Telecom, Telefónica) (source: criterios-hosting-data-residency.md).

REGLA DE ORO

Para cuantificar en el parcial: estimar costo a 3 años (el cloud "barato" se acumula); incluir staff (cloud → FinOps; on-prem → infra + FinOps); considerar elasticidad (carga 10× pico/valle → on-prem paga el pico permanente).

Criterio 3 — Latencia (la geografía manda)

TABLA 4. Latencia esperable desde Argentina (Clase 8)

Trayecto	RTT
AR → us-east-1 (Virginia)	130–160 ms
AR → us-west-1 (California)	180–220 ms
AR → sa-east-1 (São Paulo)	25–40 ms
AR → data center local	1–5 ms

- Si los usuarios están en una región y el sistema en otra, **toda interacción paga el cable submarino**.
- Para Performance con $p95 < 200$ ms, el hosting geográfico es decisión previa al diseño del backend.
- **Solución típica:** CDN/edge cerca del usuario + backend cerca de la base de datos (source: criterios-hosting-data-residency.md).

Falacias a evitar

CUÁNDO NO • CUIDADO

No afirmar sin matizar: "Cloud es siempre más barato" (depende de uso/escala/staffing); "On-prem es más seguro" (un equipo mediocre on-prem < AWS bien configurado); "Multi-cloud resuelve lock-in" (agrega complejidad que rara vez compensa); "Edge reemplaza al data center" (son complementarios: edge resuelve latencia, no durabilidad ni transactividad) (source: criterios-hosting-data-residency.md).

§6 En el parcial

EN EL PARCIAL

La estructura mínima pide **2 trade-offs explícitos**: (1) atributo vs atributo (p. ej. **SECURITY** vs Usability) y (2) **costos vs tiempo** — acá entra el hosting. Plantilla:

"Optamos por [cloud sa-east-1 / on-prem AR / colo CABA] porque (a) la regulación exige residencia en X; (b) el costo a 3 años es Y; (c) la latencia para la audiencia mayoritaria es Z ms — viable para el escenario de Performance del árbol. Trade-off: sacrificamos W (elasticidad / time-to-market / capex) a cambio de V (control / costo predecible / compliance)" (source: criterios-hosting-data-residency.md).

REGLA DE ORO

Regla de oro: nombrá el mecanismo, su **amenaza**, su **ubicación en el diagrama** y el **trade-off** que paga. Un mecanismo sin amenaza ni ubicación es decoración; la cátedra exige justificación contra el escenario del [[Árbol de utilidad]].